

APP.4.9 Objektbasierte Speicherlösungen

1 Beschreibung

1.1 Einleitung

Objektbasierte Speicherlösungen (Object Storage) sind ein zentraler Baustein moderner IT-Architekturen, insbesondere in Cloud-Umgebungen (z. B. S3-kompatible Dienste) und in großen On-Premises-Infrastrukturen (z. B. mit Ceph oder OpenStack Swift). Im Gegensatz zu traditionellen Datei- oder Blockspeichern organisieren sie Daten als einzelne Objekte in flachen Hierarchien, sogenannten Buckets. Jedes Objekt besteht aus den eigentlichen Daten, einer eindeutigen ID und Metadaten.

Der Zugriff auf Objektspeicher erfolgt fast ausschließlich über programmatische Schnittstellen (APIs), typischerweise über HTTP/HTTPS. Diese API-zentrierte Natur und ein oft sehr flexibles Berechtigungsmodell erfordern ein dediziertes Sicherheitsmanagement. Eine einzige Fehlkonfiguration in einer Bucket-Richtlinie kann dazu führen, dass große Mengen an sensiblen Daten ungeschützt offengelegt werden. Die Sicherheit von Objektspeichern hängt daher entscheidend von der korrekten Konfiguration der Zugriffsrichtlinien und der kryptografischen Absicherung der API-Endpunkte ab.

1.2 Zielsetzung

Dieser Baustein zeigt einen systematischen Weg auf, um objektbasierte Speicherlösungen sicher zu konzipieren, zu konfigurieren und zu betreiben. Ziel ist es, die Vertraulichkeit, Integrität und Verfügbarkeit der gespeicherten Objekte zu gewährleisten. Schwerpunkte sind die rigorose Kontrolle von Zugriffsberechtigungen auf Bucket- und Objektebene, die durchgängige Verschlüsselung der Daten, die Absicherung der API-Kommunikation und das lückenlose Logging aller Zugriffe.

1.3 Abgrenzung und Modellierung

Der Baustein APP.4.9 ist auf alle eingesetzten objektbasierten Speicherlösungen (Cloud-basiert sowie On-Premises) anzuwenden.

Speicherinfrastrukturen im Allgemeinen werden im Baustein SYS.1.8 Speicherlösungen behandelt. Dieser Baustein konkretisiert die Anforderungen für den spezifischen Fall des API-gesteuerten Objektspeichers. Er behandelt nicht die Absicherung der zugrundeliegenden Server-Infrastruktur bei On-Premises-Lösungen; hierfür ist der Baustein SYS.1.1 Allgemeiner Server heranzuziehen. Bei der Nutzung von Objektspeichern als Cloud-Dienst (z. B. Public Cloud) sind zwingend zusätzlich die Anforderungen aus OPS.2.2 Cloud-Nutzung umzusetzen.

2 Gefährdungslage

Für den Baustein APP.4.9 sind folgende spezifische Bedrohungen und Schwachstellen von besonderer Bedeutung:

Unbeabsichtigte Veröffentlichung von Daten durch öffentliche Buckets

Durch eine fehlerhafte Konfiguration der Zugriffsrichtlinien (Access Control Lists oder Bucket Policies) kann ein Bucket ungewollt für anonyme Dritte lesbar oder sogar beschreibbar werden. Dies führt zur vollständigen Offenlegung oder unbefugten Manipulation aller darin enthaltenen Objekte und stellt eine der häufigsten Ursachen für massenhafte Datenabflüsse in Cloud-Umgebungen dar.

Kompromittierung von API-Zugangsdaten

Der Zugriff auf Objektspeicher erfolgt meist über statische API-Schlüssel (Access Keys). Werden diese Schlüssel kompromittiert – beispielsweise, weil sie in öffentlich zugänglichem Quellcode hinterlegt wurden oder durch Phishing entwendet wurden –, erlangt ein Angreifer die gleichen Rechte wie die legitime Anwendung. Er kann dann Daten unbemerkt auslesen, manipulieren oder löschen.

Unzureichende Zugriffskontrolle auf Objektebene

Selbst wenn ein Bucket nicht vollständig öffentlich erreichbar ist, können zu weitreichende interne Berechtigungen zu Datenlecks führen. Erlaubt eine Richtlinie beispielsweise allen authentifizierten Benutzern einer Organisation pauschalen Lesezugriff, können Daten über Fachbereichs- oder Mandantengrenzen hinweg unautorisiert eingesehen werden.

Verlust oder Manipulation von Daten ohne Versionierung

Ist die Objekt-Versionierung im Bucket nicht aktiviert, wird bei einer Überschreibung eines Objekts die vorherige Version unwiederbringlich gelöscht. Dies kann durch gezielte Angriffe (z. B. Ransomware, die Objekte verschlüsselt überschreibt), aber auch durch fehlerhafte Skripte oder menschliches Versagen zum permanenten Datenverlust führen.

Ausspähen von Daten während der Übertragung

Erfolgt die Kommunikation mit den API-Endpunkten des Objektspeichers unverschlüsselt, können sowohl die übertragenen Nutzdaten als auch die zur Authentifizierung genutzten API-Schlüssel oder temporären Token im Netzwerk mitgelesen werden.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins APP.4.9 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen

werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Planer, Entwickler

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

APP.4.9.A1 Planung des Einsatzes von Objektspeichern (B) [Planer]

Vor der Einführung und Nutzung eines Objektspeichers MUSS ein Sicherheitskonzept erstellt werden. Darin MÜSSEN die zulässigen Einsatzszenarien, das Berechtigungsmodell (z. B. rollenbasierte Zugriffssteuerung) und die Anforderungen an die Verschlüsselung verbindlich geregelt werden.

APP.4.9.A2 Blockieren des öffentlichen Zugriffs (B)

Es MUSS auf der obersten administrativen Ebene des Speichersystems (z. B. auf Tenant- oder Account-Ebene) eine technische Einstellung aktiviert sein, die jeglichen öffentlichen Zugriff auf Buckets standardmäßig blockiert. Ausnahmen MÜSSEN explizit, restriktiv und nach einem definierten Genehmigungsverfahren konfiguriert werden.

APP.4.9.A3 Grundlegendes Berechtigungskonzept für Buckets (B)

Für jeden Bucket MUSS eine Zugriffsrichtlinie definiert sein, die den Zugriff auf einen explizit definierten und minimal erforderlichen Kreis von Benutzern oder Diensten beschränkt. Pauschale Freigaben DÜRFEN NICHT erteilt werden.

APP.4.9.A4 Erzwingung der Transportverschlüsselung (B)

Es MUSS sichergestellt sein, dass alle Verbindungen zu den API-Endpunkten des Objektspeichers ausschließlich über TLS-verschlüsselte Verbindungen erfolgen. Unverschlüsselte Anfragen (z. B. unverschlüsseltes HTTP) MÜSSEN serverseitig zwingend abgewiesen werden.

APP.4.9.A5 Schutz der administrativen Zugangsdaten (B)

Die primären Zugangsdaten (Root-Account, Global Administrator) des Objektspeichersystems MÜSSEN besonders geschützt aufbewahrt werden. Sie DÜRFEN NICHT für den regulären, automatisierten Zugriff durch Fachanwendungen oder zur alltäglichen Administration verwendet werden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

APP.4.9.A6 Umsetzung des Prinzips der geringsten Rechte (S)

Für jede Anwendung und jeden Benutzer SOLLTE eine dedizierte technische Identität (z. B. ein spezifischer Dienst-Account) mit eigenen API-Schlüsseln oder temporären Tokens genutzt werden. Die Berechtigungen SOLLTEN so granular wie möglich auf die zwingend benötigten Aktionen (z. B. nur lesend) und Ressourcen (spezifische Buckets oder Objektpfade) beschränkt werden.

APP.4.9.A7 Aktivierung der serverseitigen Verschlüsselung (S)

Alle in einem Bucket gespeicherten Objekte SOLLTEN standardmäßig serverseitig verschlüsselt werden (Encryption at Rest). Es SOLLTE technisch erzwungen werden, dass unverschlüsselt eingereichte Objekte beim Speichervorgang automatisch verschlüsselt oder abgewiesen werden.

APP.4.9.A8 Aktivierung der Zugriffs-Protokollierung (S)

Für alle Buckets, die schützenswerte oder geschäftskritische Daten enthalten, SOLLTE die Zugriffs-Protokollierung aktiviert werden. Alle API-Zugriffe (lesend, schreibend, löschend sowie Konfigurationsänderungen) SOLLTEN protokolliert und die Ereignisprotokolle an ein zentrales System zur Auswertung weitergeleitet werden.

APP.4.9.A9 Nutzung der Objekt-Versionierung (S)

Für Buckets mit operativ wichtigen Daten SOLLTE die Objekt-Versionierung aktiviert werden. Damit SOLLTE sichergestellt werden, dass Objekte vor unbeabsichtigtem Überschreiben oder Löschen geschützt sind und frühere Versionen wiederhergestellt werden können.

APP.4.9.A10 Regelmäßige Überprüfung der Bucket-Berechtigungen (S)

Die Konfiguration aller Bucket-Richtlinien und Zugriffskontrolllisten SOLLTE regelmäßig, vorzugsweise automatisiert, daraufhin überprüft werden, ob sie unzulässige öffentliche oder übermäßig freizügige Zugriffe erlauben. Festgestellte Abweichungen SOLLTEN unverzüglich behoben werden.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I

= Integrität, A = Verfügbarkeit).

APP.4.9.A11 Einsatz von clientseitiger Verschlüsselung (H) [Entwickler]

Für Objekte mit hochsensiblen Daten SOLLTE eine clientseitige Verschlüsselung (Client-Side Encryption) eingesetzt werden. Die Daten SOLLTEN von der Anwendung verschlüsselt werden, bevor sie an den Objektspeicher übertragen werden, sodass die Schlüssel dem Betreiber des Speichersystems nicht zugänglich sind. (C)

APP.4.9.A12 Durchsetzung von zentralen Sicherheitsrichtlinien (H)

Es SOLLTEN übergeordnete, technische Richtlinien (z. B. organisationsweite Policy-Erzwingung) etabliert werden, die es untergeordneten Administratoren und Entwicklern unmöglich machen, unsichere Konfigurationen vorzunehmen. (C, I, A)

APP.4.9.A13 Absicherung des Zugriffs über private Endpunkte (H)

Der Netzwerkzugriff auf die API des Objektspeichers SOLLTE, wann immer möglich, über private Netzwerkverbindungen erfolgen und nicht über das öffentliche Internet geroutet werden (z. B. durch private Endpunkte innerhalb eines virtuellen Netzwerks). (C, I)

APP.4.9.A14 Aktivierung der Objektsperre (Object Lock) (H)

Für Daten, die aus Nachweis- oder Revisionsgründen zwingend unveränderbar gespeichert werden müssen (WORM-Prinzip), SOLLTE die Funktion zur Objektsperre (Object Lock) genutzt werden. Diese SOLLTE so konfiguriert werden, dass eine Löschung oder Änderung eines Objekts für einen festgelegten Zeitraum technisch ausgeschlossen ist. (I)

4 Weiterführende Informationen

4.1 Wissenswertes

Praxisnahe Leitfäden für die sichere Konfiguration von Objektspeichern und Cloud-Speicherdiensten werden unter anderem von der Cloud Security Alliance (CSA) sowie dem Open Worldwide Application Security Project (OWASP) zur Verfügung gestellt.

Zusätzliche herstellerepezifische Härtingsleitfäden (wie die Security Best Practices für Amazon S3 oder Azure Blob Storage) bieten detaillierte technische Konfigurationsvorgaben, um die in diesem Baustein genannten Prinzipien auf die jeweilige Cloud-Infrastruktur abzubilden. Für kryptografische Vorgaben ist die Technische Richtlinie BSI TR-02102-1 „Kryptographische Verfahren: Empfehlungen und Schlüssellängen“ heranzuziehen.

Kreuzreferenztafel zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein APP.4.9 von Bedeutung.

Anforderung	G 0.14	G 0.18	G 0.19	G 0.22	G 0.23	G 0.31	G 0.45
APP.4.9. A1 (B)		X					
APP.4.9. A2 (B)			X			X	
APP.4.9. A3 (B)			X	X		X	
APP.4.9. A4 (B)	X		X	X			
APP.4.9. A5 (B)	X				X	X	
APP.4.9. A6 (S)			X	X	X	X	
APP.4.9. A7 (S)	X		X	X			
APP.4.9. A8 (S)					X	X	
APP.4.9. A9 (S)				X		X	X
APP.4.9. A10 (S)			X			X	
APP.4.9. A11 (H)	X		X				
APP.4.9. A12 (H)		X	X			X	
APP.4.9. A13 (H)	X		X				
APP.4.9. A14 (H)				X			X

